

Scenario 3 output 2 ollama

Here is the detailed threat modelling analysis for the given LLM-integrated account recovery and profile management system:

****1. Threat ID:** T001**

****Threat Name:** Account Takeover via User Input Tampering**

****STRIDE Category:** Elevation of Privilege**

****Affected Component/ Data Flow:** EE1, P1, DS1**

****Attack Scenario:****

* An attacker manipulates the user's input (e.g., recovery information) to gain unauthorized access to an account.

* The attacker sends a malicious request to the Web Frontend Interface (P1), which is then processed by the Account Recovery Service (P2).

****Impact:**** Unauthorized access to sensitive account data and potential control over the associated profile.

****Severity:**** High

****Likelihood:**** Medium-High

****Mitigation:****

* Implement proper input validation and sanitization on the Web Frontend Interface (P1) to prevent tampering.

* Use secure protocols for transmitting user input.

****2. Threat ID:** T002**

****Threat Name:** Recovery Token Abuse via P2 Exploitation**

****STRIDE Category:** Elevation of Privilege**

****Affected Component/ Data Flow:** P2, DS2**

****Attack Scenario:****

* An attacker exploits a vulnerability in the Account Recovery Service (P2) to gain control over recovery token generation and validation.

* The attacker uses this control to generate or validate malicious recovery tokens for unauthorized account access.

****Impact:**** Unauthorized access to sensitive account data and potential control over associated profiles.

****Severity:**** Critical

****Likelihood:**** Low-Medium

****Mitigation:****

* Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P2.

* Use secure protocols for token generation and validation.

****3. Threat ID:** T003**

****Threat Name:** Token Replay via DS2 Exploitation**

****STRIDE Category:** Elevation of Privilege**

****Affected Component/ Data Flow:** DS2, P2**

****Attack Scenario:****

* An attacker exploits a vulnerability in the Recovery Token Storage (DS2)

to gain access to and replay recovery tokens.

* The attacker uses these tokens for unauthorized account access.

****Impact:**** Unauthorized access to sensitive account data and potential control over associated profiles.

****Severity:**** High

****Likelihood:** Low-Medium**

****Mitigation:****

- * Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of DS2.
- * Use secure protocols for token storage and validation.

****4. Threat ID:** T004**

****Threat Name:** Token Leakage via P5 Exploitation**

****STRIDE Category:** Information Disclosure**

****Affected Component/ Data Flow:** P5, EE2**

****Attack Scenario:****

* An attacker exploits a vulnerability in the LLM Integration Service (P5)

to gain access to recovery tokens intended for external processing.

* The attacker uses these tokens for unauthorized account access or sells

them on the black market.

****Impact:** Unauthorized access to sensitive account data and potential financial loss.**

****Severity:** High**

****Likelihood:** Low-Medium**

****Mitigation:****

- * Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P5.
- * Use secure protocols for token transmission.

****5. Threat ID:** T005**

****Threat Name:** Identity Verification Bypass via P2 Exploitation**

****STRIDE Category:** Elevation of Privilege**

****Affected Component/ Data Flow:** P2**

****Attack Scenario:****

* An attacker exploits a vulnerability in the Account Recovery Service (P2) to bypass identity verification checks.

* The attacker uses this control to gain unauthorized access to sensitive

account data and associated profiles.

****Impact:** Unauthorized access to sensitive account data and potential control over associated profiles.**

****Severity:** Critical**

****Likelihood:** Low-Medium**

****Mitigation:****

- * Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P2.

****6. Threat ID:** T006**

****Threat Name:** Privilege Escalation via EE1 Manipulation**

****STRIDE Category:** Elevation of Privilege**

****Affected Component/ Data Flow:** EE1, DS1**

****Attack Scenario:****

* An attacker manipulates the user's input (e.g., recovery information) to

gain unauthorized access to sensitive account data and associated profiles.

* The attacker uses this control for privilege escalation, potentially gaining elevated privileges or system-level access.

****Impact:** Unauthorized access to sensitive account data, potential**

system compromise, and financial loss.

****Severity:**** Critical

****Likelihood:**** Medium-High

****Mitigation:****

- * Implement proper input validation and sanitization on the Web Frontend Interface (P1) to prevent tampering.

- * Use secure protocols for transmitting user input.

****7. Threat ID:**** T007

****Threat Name:**** Unauthorized Profile Modification via P3 Exploitation

****STRIDE Category:**** Data Tampering

****Affected Component/ Data Flow:**** P3, DS1

****Attack Scenario:****

- * An attacker exploits a vulnerability in the Profile Management Service (P3) to gain unauthorized access and modification of sensitive account data.

- * The attacker uses this control for malicious purposes, such as identity theft or financial exploitation.

****Impact:**** Unauthorized modification of sensitive account data and potential financial loss.

****Severity:**** High

****Likelihood:**** Low-Medium

****Mitigation:****

- * Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P3.

****8. Threat ID:**** T008

****Threat Name:**** Prompt Injection via EE1 Manipulation

****STRIDE Category:**** Elevation of Privilege

****Affected Component/ Data Flow:**** EE1, P5

****Attack Scenario:****

- * An attacker manipulates the user's input (e.g., recovery information) to inject malicious prompts into the LLM Integration Service (P5).

- * The attacker uses this control for unauthorized access or data tampering.

****Impact:**** Unauthorized access to sensitive account data and potential system compromise.

****Severity:**** Critical

****Likelihood:**** Medium-High

****Mitigation:****

- * Implement proper input validation and sanitization on the Web Frontend Interface (P1) to prevent tampering.

****9. Threat ID:**** T009

****Threat Name:**** Sensitive Information Disclosure via P5 Exploitation

****STRIDE Category:**** Information Disclosure

****Affected Component/ Data Flow:**** P5, EE2

****Attack Scenario:****

- * An attacker exploits a vulnerability in the LLM Integration Service (P5)

- to gain access to sensitive account data and associated profiles.

- * The attacker uses this information for malicious purposes, such as identity theft or financial exploitation.

****Impact:**** Unauthorized disclosure of sensitive account data and

potential financial loss.

****Severity:**** High

****Likelihood:**** Low-Medium

****Mitigation:****

* Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P5.

****10. Threat ID:**** T010

****Threat Name:**** Insecure Output Handling via EE2 Exploitation

****STRIDE Category:**** Data Tampering

****Affected Component/ Data Flow:**** EE2

****Attack Scenario:****

* An attacker exploits a vulnerability in the External LLM Provider (EE2)

to gain unauthorized access and modify output.

* The attacker uses this control for malicious purposes, such as data tampering or financial exploitation.

****Impact:**** Unauthorized modification of sensitive account data and potential financial loss.

****Severity:**** High

****Likelihood:**** Low-Medium

****Mitigation:****

* Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of EE2.

****11. Threat ID:**** T011

****Threat Name:**** Excessive AI Agency via P4 Exploitation

****STRIDE Category:**** Elevation of Privilege

****Affected Component/ Data Flow:**** P4

****Attack Scenario:****

* An attacker exploits a vulnerability in the AI Account Support Assistant

(P4) to gain unauthorized access and influence recovery decisions.

* The attacker uses this control for malicious purposes, such as identity

theft or financial exploitation.

****Impact:**** Unauthorized influence over sensitive account data and potential system compromise.

****Severity:**** Critical

****Likelihood:**** Low-Medium

****Mitigation:****

* Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of P4.

****12. Threat ID:**** T012

****Threat Name:**** External LLM Risks via EE2 Exploitation

****STRIDE Category:**** Information Disclosure

****Affected Component/ Data Flow:**** EE2

****Attack Scenario:****

* An attacker exploits a vulnerability in the External LLM Provider (EE2)

to gain unauthorized access and disclose sensitive account data.

* The attacker uses this information for malicious purposes, such as identity theft or financial exploitation.

****Impact:**** Unauthorized disclosure of sensitive account data and potential financial loss.

****Severity:**** High
****Likelihood:**** Low-Medium
****Mitigation:****
* Implement robust security measures, such as regular audits and penetration testing, to ensure the integrity of EE2.

OWASP LLM Top 10 mapping:

T001 – Account Takeover via User Input Tampering maps to OWASP LLM Top 10 category: "Insufficient Validation".

T002 – Recovery Token Abuse via P2 Exploitation maps to OWASP LLM Top 10 category: "Insecure Data Processing".

T003 – Token Replay via DS2 Exploitation maps to OWASP LLM Top 10 category: "Data Tampering".

T004 – Token Leakage via P5 Exploitation maps to OWASP LLM Top 10 category: "Insufficient Validation".

T005 – Identity Verification Bypass via P2 Exploitation maps to OWASP LLM Top 10 category: "Insecure Data Processing".

T006 – Privilege Escalation via EE1 Manipulation maps to OWASP LLM Top 10 category: "Elevation of Privilege".

T007 – Unauthorized Profile Modification via P3 Exploitation maps to OWASP LLM Top 10 category: "Data Tampering".

T008 – Prompt Injection via EE1 Manipulation maps to OWASP LLM Top 10 category: "Insecure Data Processing".

T009 – Sensitive Information Disclosure via P5 Exploitation maps to OWASP LLM Top 10 category: "Information Disclosure".

T010 – Insecure Output Handling via EE2 Exploitation maps to OWASP LLM Top 10 category: "Data Tampering".

T011 – Excessive AI Agency via P4 Exploitation maps to OWASP LLM Top 10 category: "Elevation of Privilege".

T012 – External LLM Risks via EE2 Exploitation maps to OWASP LLM Top 10 category: "Information Disclosure".